

Charte de sécurité des systèmes d'information

Règles d'usage, authentification, protection des données et gestion des incidents

Référence	SSI-CHT-2026-002	Version	6.0
Auteur	Direction de la Sécurité des Systèmes d'Information — Nadia Cherif, RSSI	Date	30/06/2026
Entité	DSI — Pôle Sécurité et Conformité	Diffusion	Interne — Opposable à l'ensemble des utilisateurs

Résumé

La présente charte définit les règles d'usage du système d'information et les obligations de sécurité applicables à l'ensemble des collaborateurs, stagiaires, alternants, prestataires et partenaires disposant d'un accès aux ressources numériques de l'organisation. Elle couvre la gestion des identités et l'authentification multifacteur, la politique de mots de passe, la lutte contre l'hameçonnage et l'ingénierie sociale, les modalités d'accès distant par VPN et l'architecture zero trust, la sécurisation des postes de travail, la classification et la protection des données, l'usage de la messagerie et des outils collaboratifs, la journalisation et la détection, ainsi que la procédure de signalement et de traitement des incidents. Elle est annexée au règlement intérieur et son acceptation conditionne l'ouverture des accès.

Mots-clés : MFA · mot de passe · phishing · VPN · chiffrement · zero trust · authentification · hameçonnage · incident de sécurité · RGPD

Sommaire

1. Objet, périmètre d'application et engagements réciproques
2. Gestion des identités, des accès et cycle de vie des comptes
3. Authentification multifacteur (MFA) : principes et mise en œuvre
4. Politique de mots de passe et gestion des secrets
5. Hameçonnage, ingénierie sociale et fraude au président
6. Accès distant, VPN et architecture zero trust
7. Sécurisation des postes de travail et des terminaux mobiles
8. Classification, protection et cycle de vie des données
9. Messagerie, outils collaboratifs et partage avec l'extérieur
10. Journalisation, supervision et respect de la vie privée
11. Signalement, qualification et traitement des incidents de sécurité
12. Conformité, sensibilisation, contrôle et évolution de la charte

1. Objet, périmètre d'application et engagements réciproques

La charte encadre l'usage des ressources numériques mises à disposition et précise les droits comme les devoirs de chacune des parties.

La présente charte s'applique à toute personne physique disposant d'un compte nominatif ou d'un accès, même temporaire, au système d'information de l'organisation. Sont concernés les salariés en contrat à durée indéterminée ou déterminée, les intérimaires, les stagiaires et alternants, les prestataires intervenant dans le cadre d'un contrat de service, les auditeurs externes et les partenaires bénéficiant d'un accès à un espace collaboratif. Elle couvre l'ensemble des ressources : postes de travail fixes et portables, terminaux mobiles, applications métier, messagerie, espaces de stockage, réseaux filaires et sans fil, services d'infrastructure hébergés en interne ou dans le cloud, et comptes à privilèges d'administration.

L'organisation s'engage de son côté à fournir des outils adaptés aux besoins professionnels, à assurer leur maintien en condition de sécurité, à informer les utilisateurs des mesures de surveillance mises en œuvre et de leur finalité, à respecter la confidentialité des correspondances identifiées comme personnelles, et à proportionner les contrôles à l'objectif poursuivi. Elle met à disposition un support technique joignable aux heures ouvrées et une adresse de signalement des incidents de sécurité accessible en permanence. Elle assure enfin un programme de sensibilisation annuel obligatoire dont le suivi conditionne le maintien de certains accès sensibles.

L'utilisateur s'engage à utiliser les ressources dans le cadre de son activité professionnelle, à respecter les règles techniques et organisationnelles décrites dans les chapitres suivants, à signaler sans délai tout événement suspect ou toute erreur de manipulation susceptible d'affecter la sécurité, et à ne pas contourner les mesures de protection mises en place. Un usage privé résiduel des outils est toléré à condition qu'il reste marginal, qu'il ne compromette ni la sécurité ni la performance des systèmes, et qu'il n'engage pas l'organisation. Les fichiers et messages à caractère privé doivent être explicitement identifiés comme tels par la mention « personnel » dans leur intitulé.

Usages formellement interdits

- Partager ou céder ses identifiants de connexion, y compris à un collègue ou à un supérieur.
- Utiliser le compte d'un tiers, même avec son accord explicite.
- Installer un logiciel non validé par la DSI sur un poste appartenant à l'organisation.
- Contourner un dispositif de filtrage, un proxy, un antivirus ou une politique de groupe.
- Connecter un équipement personnel non déclaré sur le réseau interne filaire.
- Extraire des données de l'organisation vers un service de stockage personnel non validé.
- Réaliser des tests d'intrusion ou des scans réseau sans autorisation écrite préalable.
- Stocker des données professionnelles sensibles sur un support amovible non chiffré.

Point d'attention. *Le non-respect de la charte peut donner lieu à des sanctions disciplinaires proportionnées à la gravité des faits, sans préjudice des poursuites civiles ou pénales que la loi permettrait d'engager.*

2. Gestion des identités, des accès et cycle de vie des comptes

Le principe du moindre privilège gouverne l'attribution des droits : chacun dispose des accès strictement nécessaires à sa mission, pour la durée strictement nécessaire.

Chaque utilisateur se voit attribuer un identifiant nominatif unique, construit selon une convention de nommage stable et non réattribuable. Les comptes génériques et les comptes partagés sont proscrits, à l'exception de quelques comptes de service techniques dont la liste est tenue à jour par la DSI, dont les secrets sont stockés dans le coffre-fort d'entreprise, et dont l'usage est systématiquement tracé et associé à une identité humaine responsable. Cette exigence de nominativité est la condition première de l'imputabilité : sans elle, aucune investigation post-incident ne peut établir qui a réalisé quelle action.

L'attribution des droits repose sur un modèle de contrôle d'accès fondé sur les rôles. Chaque poste de l'organisation est associé à un profil type regroupant les habilitations nécessaires à l'exercice de la fonction. Toute demande d'accès supplémentaire, dérogatoire au profil, doit être formulée par le responsable hiérarchique, justifiée par un besoin métier explicite, validée par le propriétaire de la donnée ou de l'application concernée, et assortie d'une date d'échéance. Les accès dérogatoires sans échéance sont interdits ; à défaut de date précisée, une durée par défaut de quatre-vingt-dix jours s'applique automatiquement.

Le cycle de vie des comptes est aligné sur les événements de gestion des ressources humaines par un connecteur automatisé. L'arrivée déclenche la création du compte et l'attribution du profil correspondant au poste, la mobilité interne déclenche une revue complète des droits avec suppression systématique des habilitations liées à l'ancien poste, et le départ déclenche la désactivation immédiate du compte à la date de fin de contrat, suivie de sa suppression après une période de rétention de quatre-vingt-dix jours permettant la récupération des données professionnelles par le responsable hiérarchique. Une revue trimestrielle des habilitations est conduite par les propriétaires d'applications sur l'ensemble du périmètre sensible.

Niveaux de privilège et exigences associées

Niveau	Population	Authentification	Revue	Journalisation
Standard	Tous les utilisateurs	MFA obligatoire	Annuelle	Connexions
Sensible métier	Finance, RH, juridique	MFA obligatoire, réauth. 8 h	Trimestrielle	Connexions et accès données
Administrateur applicatif	Référents applicatifs	MFA renforcée, compte dédié	Trimestrielle	Toutes actions
Administrateur système	Équipe infrastructure	MFA matérielle, poste durci	Mensuelle	Session complète enregistrée
Accès d'urgence	Astreinte	MFA matérielle, secret scellé	À chaque usage	Alerte temps réel au SOC
Prestataire externe	Contrats de service	MFA obligatoire, plage horaire	Mensuelle	Session complète enregistrée

Point d'attention. *Un administrateur dispose de deux comptes distincts : un compte standard pour la bureautique et la messagerie, un compte à privilèges strictement réservé aux tâches d'administration, sans accès Internet ni messagerie.*

3. Authentification multifacteur (MFA) : principes et mise en œuvre

Le mot de passe seul ne protège plus rien : l'authentification multifacteur est la mesure de sécurité au meilleur rapport efficacité-coût de la décennie.

L'authentification multifacteur repose sur la combinaison d'au moins deux facteurs de nature différente parmi trois catégories : un facteur de connaissance, c'est-à-dire quelque chose que l'utilisateur sait, typiquement un mot de passe ou un code PIN ; un facteur de possession, quelque chose qu'il détient, comme une clé de sécurité matérielle, un téléphone enrôlé ou une carte à puce ; et un facteur d'inhérence, quelque chose qu'il est, à savoir une caractéristique biométrique. L'exigence de nature différente est essentielle : deux mots de passe successifs ne constituent pas une authentification multifacteur, pas plus qu'un mot de passe suivi d'une question secrète, qui relève également de la connaissance.

Tous les mécanismes de second facteur n'offrent pas le même niveau de protection. Le code envoyé par SMS constitue le maillon le plus faible : il est vulnérable à l'interception, au détournement de carte SIM par ingénierie sociale auprès de l'opérateur, et aux attaques par relais en temps réel. L'application d'authentification générant un code à usage unique fondé sur le temps, dite TOTP, offre un niveau nettement supérieur mais reste vulnérable au phishing en temps réel où l'attaquant relaie le code saisi par la victime. Seules les clés de sécurité matérielles conformes au standard FIDO2 et WebAuthn résistent structurellement à l'hameçonnage, car la signature cryptographique produite est liée au nom de domaine réel du service, ce qui rend le relais techniquement impossible.

Le déploiement au sein de l'organisation est différencié selon la sensibilité des accès. L'authentification multifacteur est obligatoire pour l'ensemble des utilisateurs sur tous les services exposés sur Internet, sans exception ni dérogation. Les clés FIDO2 sont imposées pour les comptes à privilèges, les populations exposées, notamment le comité de direction et les équipes finance, et l'accès aux environnements de production. Le SMS a été intégralement retiré du catalogue des facteurs disponibles en janvier 2026. Chaque utilisateur enrôle au minimum deux facteurs afin d'éviter tout blocage en cas de perte ou de panne du premier, et dispose de codes de secours à conserver hors du système d'information.

Comparatif des facteurs d'authentification déployés

Facteur	Catégorie	Résistance phishing	Résistance vol d'appareil	Statut interne
Mot de passe	Connaissance	Nulle	Élevée	Premier facteur uniquement
Code SMS	Possession	Nulle	Faible	Retiré en janvier 2026
Application TOTP	Possession	Faible	Moyenne	Autorisé, standard
Notification push avec correspondance de code	Possession	Moyenne	Moyenne	Autorisé, standard
Clé de sécurité FIDO2	Possession	Élevée	Élevée	Obligatoire, comptes sensibles

Facteur	Catégorie	Résistance phishing	Résistance vol d'appareil	Statut interne
Passkey synchronisée	Possession	Élevée	Moyenne	Autorisé hors production
Biométrie locale de l'appareil	Inhérence	Non applicable	Élevée	Déverrouillage local seul

Point d'attention. La fatigue MFA est une technique d'attaque réelle : l'attaquant multiplie les notifications push jusqu'à ce que la victime accepte par lassitude. Toute notification non sollicitée doit être refusée et signalée immédiatement.

4. Politique de mots de passe et gestion des secrets

La longueur prime sur la complexité, et le renouvellement systématique fait plus de mal que de bien.

La politique de mots de passe a été révisée en profondeur pour s'aligner sur l'état de l'art actuel, qui rompt avec les pratiques héritées des années 2000. Les recommandations en vigueur privilégient désormais des mots de passe longs, d'au moins douze caractères pour un compte standard protégé par MFA et d'au moins vingt caractères pour un compte à privilèges, plutôt que des mots de passe courts et complexes. L'obligation de mêler majuscules, chiffres et caractères spéciaux produit en pratique des schémas prévisibles, du type première lettre en majuscule et point d'exclamation final, que les outils de cassage exploitent efficacement. L'entropie réelle d'une phrase de passe de quatre mots aléatoires dépasse celle d'un mot de passe de huit caractères complexes.

Le renouvellement périodique obligatoire a été supprimé pour les comptes standard. Imposer un changement tous les quatre-vingt-dix jours conduit les utilisateurs à adopter des variations incrémentales triviales, à réutiliser des mots de passe connus ou à les noter, ce qui dégrade la sécurité au lieu de l'améliorer. Le renouvellement n'est désormais imposé que sur événement : suspicion de compromission, apparition de l'identifiant dans une fuite de données publique détectée par le service de veille, départ d'un administrateur ayant eu connaissance d'un secret partagé, ou incident de sécurité avéré. Cette approche est complétée par un contrôle systématique du mot de passe choisi contre une base de plusieurs centaines de millions de mots de passe compromis.

Le gestionnaire de mots de passe d'entreprise est déployé pour l'ensemble des collaborateurs et son usage est obligatoire pour tout secret professionnel. Il permet de générer des mots de passe uniques et aléatoires pour chaque service, de les stocker chiffrés localement avec une clé dérivée du mot de passe maître, et de les partager de manière contrôlée au sein d'un coffre d'équipe lorsque le partage est techniquement inévitable. Le mot de passe maître constitue le point de défaillance unique : il doit être une phrase de passe longue, unique, mémorisée et jamais réutilisée, protégée par un second facteur matériel. La conservation de secrets professionnels dans un navigateur, un fichier texte, un tableur ou une note de téléphone est formellement interdite.

Interdictions relatives aux secrets

- Réutiliser un mot de passe professionnel sur un service personnel, et réciproquement.
- Inscrire un secret dans le code source, un fichier de configuration ou une variable de dépôt Git.
- Transmettre un mot de passe par messagerie électronique, message instantané ou SMS.
- Enregistrer un mot de passe professionnel dans le gestionnaire intégré d'un navigateur personnel.
- Conserver un secret dans un ticket d'assistance, un compte rendu ou une note de réunion.
- Dicter un mot de passe au téléphone, y compris à un membre identifié du support.

Exigences par type de compte

Type de compte	Longueur minimale	MFA	Renouvellement	Stockage
Utilisateur standard	12 caractères	Obligatoire	Sur événement	Gestionnaire d'entreprise

Type de compte	Longueur minimale	MFA	Renouvellement	Stockage
Utilisateur sensible métier	14 caractères	Obligatoire	Sur événement	Gestionnaire d'entreprise
Administrateur applicatif	20 caractères	FIDO2	Sur événement	Coffre-fort à privilèges
Administrateur système	24 caractères	FIDO2	Sur événement	Coffre-fort à privilèges
Compte de service	32 caractères aléatoires	Non applicable	Rotation automatique 90 jours	Coffre-fort applicatif
Accès d'urgence	32 caractères aléatoires	FIDO2 + validation à deux	Après chaque usage	Enveloppe scellée en coffre

Point d'attention. Le support technique ne demandera jamais votre mot de passe, sous aucun prétexte, par aucun canal. Toute demande en ce sens constitue par définition une tentative d'attaque et doit être signalée.

5. Hameçonnage, ingénierie sociale et fraude au président

Plus de huit compromissions sur dix commencent par un courriel : la vigilance humaine reste la première ligne de défense.

L'hameçonnage consiste à usurper l'identité d'un tiers de confiance pour amener la victime à divulguer des informations, à saisir ses identifiants sur un site contrefait ou à exécuter une pièce jointe malveillante. Les campagnes de masse, grossières et truffées de fautes, ont largement cédé la place à des attaques ciblées, dites harponnage, exploitant des informations réelles collectées sur les réseaux sociaux professionnels, les communiqués de presse et les fuites de données antérieures. Un courriel de harponnage bien construit mentionne le nom exact du responsable hiérarchique, un projet en cours et une échéance plausible : sa détection ne peut plus reposer sur la seule recherche de fautes d'orthographe.

La fraude au président constitue une variante à fort enjeu financier. L'attaquant, après une phase d'observation parfois longue permise par la compromission d'une boîte aux lettres, se fait passer pour un dirigeant et sollicite un virement urgent et confidentiel auprès d'un collaborateur du service comptable, en invoquant une opération de croissance externe soumise au secret. Les leviers psychologiques mobilisés sont systématiquement l'autorité, l'urgence, la confidentialité et la flatterie. La contre-mesure n'est pas technique mais procédurale : toute modification de coordonnées bancaires d'un fournisseur et tout virement exceptionnel au-delà d'un seuil défini font l'objet d'une validation par un canal indépendant, à un numéro de téléphone connu préalablement et jamais à celui indiqué dans le message.

Le dispositif de signalement repose sur un bouton intégré à la messagerie permettant de transmettre un message suspect au centre opérationnel de sécurité en un clic, sans transfert manuel qui altérerait les en-têtes techniques nécessaires à l'analyse. Le signalement est encouragé même en cas de doute et n'expose son auteur à aucune conséquence négative, y compris lorsqu'il a déjà cliqué sur le lien : la rapidité du signalement conditionne directement la capacité à limiter l'impact. Le délai médian de signalement, actuellement de 34 minutes, constitue un indicateur suivi mensuellement au même titre que le taux de clic lors des campagnes de simulation trimestrielles.

Signaux d'alerte à vérifier avant toute action

- L'adresse d'expédition réelle diffère du nom affiché ; vérifier le domaine complet après l'arobase.
- Le message crée un sentiment d'urgence ou menace d'une conséquence immédiate.
- Il demande la confidentialité et décourage la vérification auprès de tiers.
- Le lien affiché ne correspond pas à la cible réelle visible au survol du curseur.
- Le domaine du lien comporte une substitution de caractère ou un suffixe inhabituel.
- Une pièce jointe inattendue demande l'activation des macros ou l'exécution d'un script.
- Le message sollicite des identifiants, un code MFA ou une modification de coordonnées bancaires.
- Le contexte ne correspond à aucune demande antérieure identifiable de l'expéditeur supposé.

Indicateurs des campagnes de simulation d'hameçonnage

Trimestre	Destinataires	Taux de clic	Taux de saisie	Taux de signalement	Délai médian
T1 2025	1 840	18,4 %	6,2 %	21,0 %	1 h 52
T2 2025	1 862	14,1 %	4,1 %	29,7 %	1 h 09
T3 2025	1 871	11,8 %	2,9 %	38,2 %	52 min
T4 2025	1 903	9,6 %	1,7 %	44,5 %	41 min
T1 2026	1 925	8,2 %	1,1 %	51,3 %	34 min

Point d'attention. Un utilisateur qui signale rapidement après avoir cliqué rend un service considérable à l'organisation. La culture du signalement sans crainte de sanction est un objectif explicite de la politique de sécurité.

6. Accès distant, VPN et architecture zero trust

La disparition du périmètre réseau impose de vérifier explicitement chaque accès plutôt que de faire confiance à la localisation de l'utilisateur.

L'accès distant aux ressources internes s'effectue exclusivement via le client VPN d'entreprise déployé sur les postes gérés, qui établit un tunnel chiffré selon les suites cryptographiques validées par la DSI. Le VPN est configuré en mode tunnel intégral, ce qui signifie que l'ensemble du trafic du poste, y compris la navigation Internet, transite par les passerelles de l'organisation où s'appliquent le filtrage d'URL, l'inspection antivirus et la journalisation. Le mode tunnel partagé, qui laisserait une partie du trafic sortir directement, est désactivé car il créerait un pont potentiel entre le réseau interne et un réseau domestique non maîtrisé.

La connexion VPN exige une authentification multifacteur et une vérification de l'état de conformité du poste avant l'ouverture du tunnel. Cette vérification porte sur la présence et l'activité de l'agent de protection des postes, le niveau de correctif du système d'exploitation, l'activation du chiffrement du disque et l'absence d'indicateur de compromission connu. Un poste non conforme est placé en quarantaine réseau, avec un accès restreint aux seuls serveurs de mise à jour, et l'utilisateur reçoit un message précisant la remédiation attendue. Cette vérification est réévaluée périodiquement pendant la session et non uniquement à son ouverture.

L'organisation conduit depuis 2024 une transition progressive vers une architecture zero trust pour les applications exposées. Le principe consiste à ne jamais accorder de confiance implicite fondée sur la position réseau, mais à évaluer chaque requête d'accès en fonction de l'identité vérifiée de l'utilisateur, de l'état de son terminal, du contexte de la demande et de la sensibilité de la ressource. Concrètement, les applications migrées ne sont plus accessibles par le VPN mais par un mandataire d'accès applicatif qui applique une politique conditionnelle à chaque requête. Cette approche réduit drastiquement la surface d'attaque en supprimant l'exposition du réseau interne dans son ensemble à un poste compromis.

Politique d'accès conditionnel appliquée

Contexte	Poste géré conforme	Poste géré non conforme	Terminal personnel
Réseau interne, heures ouvrées	Accès complet	Quarantaine	Portail web seul
Domicile, pays de résidence	Accès complet avec MFA	Quarantaine	Portail web seul avec MFA
Déplacement, pays autorisé	Accès complet avec MFA	Refus	Messagerie seule avec MFA
Pays hors liste autorisée	Accès sur dérogation nominative	Refus	Refus
Adresse IP en liste noire de menaces	Refus et alerte SOC	Refus et alerte SOC	Refus et alerte SOC
Voyage impossible détecté	Refus, session révoquée, alerte	Refus et alerte	Refus et alerte

Point d'attention. *L'usage d'un réseau Wi-Fi public reste possible avec le VPN actif, mais jamais avant son établissement. Ne saisir aucun identifiant tant que le tunnel n'est pas confirmé actif par l'icône du client.*

7. Sécurisation des postes de travail et des terminaux mobiles

Le poste de travail est à la fois l'outil de production principal et la cible privilégiée des attaquants.

Tous les postes de travail sont fournis, configurés et administrés par la DSI selon un socle de durcissement standardisé. Ce socle comprend le chiffrement intégral du disque avec séquestre de la clé de récupération, l'activation du démarrage sécurisé et du module de plateforme sécurisée, la suppression des droits d'administration locale pour l'utilisateur courant, l'application automatique des correctifs de sécurité, le déploiement d'un agent de détection et de réponse sur les terminaux, et une politique de verrouillage automatique de session après cinq minutes d'inactivité. Ce socle est audité mensuellement par un outil de contrôle de conformité dont les écarts alimentent un tableau de bord de remédiation.

La gestion des correctifs suit une politique fondée sur la criticité et l'exploitabilité. Une vulnérabilité critique activement exploitée doit être corrigée sous quarante-huit heures sur les systèmes exposés et sous sept jours sur l'ensemble du parc. Une vulnérabilité critique sans exploitation connue dispose d'un délai de quinze jours, une vulnérabilité importante de trente jours, et les vulnérabilités de moindre gravité sont traitées dans le cycle de mise à jour trimestriel. Ces délais s'appliquent également aux serveurs et aux équipements réseau ; toute exception doit être formellement acceptée par le RSSI avec une mesure de contournement documentée et une date de résorption.

Les terminaux mobiles, qu'ils soient fournis par l'organisation ou personnels dans le cadre du dispositif d'usage mixte, sont enrôlés dans la solution de gestion unifiée des terminaux. Sur un terminal personnel, seul un conteneur professionnel chiffré est administré : l'organisation n'accède à aucune donnée personnelle, ne consulte ni les photographies, ni les messages privés, ni la localisation, et l'effacement à distance ne porte que sur le conteneur professionnel. Cette séparation est une exigence à la fois de respect de la vie privée et de sécurité juridique, et son fonctionnement technique est documenté dans une notice remise lors de l'enrôlement.

Règles applicables au poste de travail

- Verrouiller systématiquement la session en quittant le poste, même brièvement.
- Ne jamais désactiver l'agent de sécurité ni le pare-feu local, y compris temporairement.
- Redémarrer le poste au moins une fois par semaine pour permettre l'application des correctifs.
- Signaler immédiatement tout comportement anormal : lenteur soudaine, fenêtre inattendue, fichier chiffré.
- Ne pas connecter de support amovible d'origine inconnue, y compris trouvé dans les locaux.
- Déclarer sans délai la perte ou le vol d'un équipement pour déclencher l'effacement à distance.
- Utiliser un filtre de confidentialité lors du travail en espace public ou en transport.
- Restituer l'intégralité du matériel lors du départ de l'organisation.

Délais de correction des vulnérabilités

Criticité	Exploitation connue	Systèmes exposés	Parc interne	Dérogation
Critique	Oui, active	48 heures	7 jours	RSSI uniquement
Critique	Non	7 jours	15 jours	RSSI uniquement
Importante	Oui	7 jours	15 jours	Responsable sécurité opérationnelle
Importante	Non	15 jours	30 jours	Responsable sécurité opérationnelle
Moyenne	Indifférent	30 jours	90 jours	Cycle trimestriel
Faible	Indifférent	90 jours	Prochain cycle majeur	Non requise

8. Classification, protection et cycle de vie des données

On ne protège correctement que ce que l'on a classé : la classification conditionne le niveau de protection applicable.

L'organisation applique une classification à quatre niveaux, du moins au plus sensible : public, interne, confidentiel et secret. Le niveau public désigne les informations dont la diffusion est libre, comme les communiqués et les plaquettes commerciales. Le niveau interne couvre l'essentiel de la production quotidienne, dont la divulgation ne causerait qu'un préjudice limité. Le niveau confidentiel s'applique aux données dont la divulgation causerait un préjudice significatif : données à caractère personnel, informations financières non publiées, contrats, documents de propriété intellectuelle. Le niveau secret est réservé à un périmètre restreint : opérations de croissance externe, litiges majeurs, secrets industriels stratégiques.

La responsabilité de la classification incombe au producteur du document, qui appose l'étiquette correspondante dès la création. L'outil bureautique intègre un mécanisme d'étiquetage obligatoire qui empêche l'enregistrement d'un document non classé et qui applique automatiquement les protections techniques associées : chiffrement au niveau du document, restriction d'impression et de copie, filigrane nominatif, blocage du partage externe. Ces protections voyagent avec le fichier, y compris s'il est extrait du système d'information, ce qui constitue l'apport essentiel de cette approche par rapport à un simple contrôle d'accès sur un espace de stockage.

La durée de conservation est définie par le référentiel de conservation, qui articule les obligations légales, les besoins métier et le principe de minimisation issu du règlement général sur la protection des données. Conserver au-delà du nécessaire n'est pas une précaution mais un risque : chaque donnée conservée inutilement élargit la surface d'exposition en cas de compromission et constitue un manquement en cas de contrôle. La purge automatique est activée sur les espaces collaboratifs et la messagerie selon les durées du référentiel, avec une notification préalable trente jours avant suppression et une possibilité de prolongation motivée.

Matrice de classification et mesures de protection

Niveau	Exemples	Partage externe	Chiffrement	Conservation type
Public	Communiqués, plaquettes, offres d'emploi	Libre	Non requis	Illimitée
Interne	Comptes rendus, procédures, notes	Sur autorisation	En transit	3 à 5 ans
Confidentiel	Données personnelles, contrats, budgets	Accord écrit et NDA	Au repos et en transit	Selon référentiel
Secret	Fusions-acquisitions, litiges, brevets	Interdit sauf décision COMEX	Chiffrement documentaire nominatif	Durée du projet + 10 ans

Point d'attention. *Un document non classé est traité par défaut au niveau interne. Cette valeur par défaut ne dispense pas de classer explicitement : elle protège insuffisamment les données confidentielles.*

9. Messagerie, outils collaboratifs et partage avec l'extérieur

La messagerie concentre à la fois le principal vecteur d'attaque et le principal risque de fuite involontaire.

La messagerie professionnelle est protégée par une chaîne de contrôles techniques comprenant l'authentification de l'expéditeur par les mécanismes SPF, DKIM et DMARC en politique de rejet, le filtrage antispam et antimalware, la réécriture des liens permettant une analyse au moment du clic, la détonation des pièces jointes en environnement isolé, et l'apposition d'une bannière visible sur tout message provenant de l'extérieur de l'organisation. Ces contrôles arrêtent la grande majorité des menaces mais ne dispensent en aucun cas de la vigilance individuelle, les attaques les plus ciblées étant précisément conçues pour franchir les filtres automatiques.

Le partage de documents avec des tiers s'effectue exclusivement via les espaces collaboratifs validés, au moyen de liens nominatifs assortis d'une date d'expiration et d'un niveau de droit explicite. Le partage par lien ouvert accessible à toute personne disposant de l'adresse est désactivé pour les documents classés confidentiel et secret, et limité à trente jours pour les autres. L'envoi de pièces jointes volumineuses par messagerie est découragé au profit du lien de partage, qui présente le double avantage de conserver la maîtrise de l'accès après l'envoi et de permettre la révocation en cas d'erreur de destinataire.

L'erreur de destinataire constitue d'ailleurs la première cause de violation de données déclarée dans l'organisation, devant l'hameçonnage et la perte d'équipement. Le mécanisme de complétion automatique des adresses, qui propose des destinataires sur la base des premières lettres saisies, en est le principal facteur. Une temporisation de trente secondes avant envoi effectif a été activée pour tous les utilisateurs, permettant le rappel du message, et une alerte s'affiche lorsqu'un message contenant une pièce jointe classée confidentiel est adressé à un domaine externe. Toute erreur de destinataire portant sur des données personnelles doit être signalée au délégué à la protection des données dans les meilleurs délais.

Bonnes pratiques de messagerie

- Vérifier la liste complète des destinataires avant tout envoi contenant une pièce jointe.
- Privilégier le lien de partage nominatif à la pièce jointe pour les documents sensibles.
- Utiliser la copie cachée pour toute diffusion à un grand nombre de destinataires externes.
- Ne pas transférer une conversation interne à l'extérieur sans en relire l'intégralité de l'historique.
- Purger les métadonnées et le suivi des modifications avant transmission d'un document externe.
- Configurer une réponse d'absence sobre, sans mention de la durée exacte ni de coordonnées personnelles.
- Signaler par le bouton dédié tout message suspect plutôt que de le supprimer.

Point d'attention. La bannière « expéditeur externe » n'est pas un avertissement de danger mais une information de contexte. Un message externe légitime en porte une ; un message interne usurpé n'en porte pas.

10. Journalisation, supervision et respect de la vie privée

La détection suppose la collecte : la charte précise ce qui est journalisé, pourquoi, pendant combien de temps et qui y accède.

L'organisation collecte et centralise les journaux techniques de l'ensemble de son système d'information au sein d'une plateforme de gestion des événements de sécurité, exploitée par un centre opérationnel de sécurité en service continu. Sont notamment collectés les journaux d'authentification, les événements des agents de protection des postes, les journaux des équipements réseau et de sécurité périmétrique, les journaux d'accès aux applications sensibles et les journaux d'administration. La finalité exclusive de cette collecte est la détection, l'investigation et la réponse aux incidents de sécurité, ainsi que le respect des obligations légales de conservation.

Cette surveillance s'exerce dans le respect du principe de proportionnalité et des droits des personnes. Elle porte sur des événements techniques et non sur le contenu des communications : le contenu d'un courriel n'est jamais consulté hors procédure d'investigation formellement ouverte et validée conjointement par le RSSI, le délégué à la protection des données et la direction des ressources humaines. Aucun dispositif de surveillance individualisée permanente n'est déployé, aucune capture d'écran périodique n'est réalisée, et aucun outil de mesure de productivité individuelle n'est en place. Les représentants du personnel ont été informés et consultés préalablement à la mise en œuvre de ces traitements, inscrits au registre des activités de traitement.

Les durées de conservation des journaux sont différenciées selon leur nature et leur finalité. Les journaux de connexion sont conservés douze mois, durée alignée sur les besoins d'investigation constatés, un attaquant demeurant en moyenne plusieurs mois dans un système avant détection. Les journaux d'administration à privilèges sont conservés vingt-quatre mois compte tenu de leur criticité. L'accès aux journaux est strictement limité aux analystes du centre opérationnel de sécurité, lui-même journalisé et soumis à une revue mensuelle indépendante, afin de garantir que la surveillance des systèmes ne se transforme pas en surveillance des personnes.

Traitements de journalisation et durées de conservation

Catégorie de journal	Données collectées	Durée	Accès
Authentification	Identifiant, horodatage, IP, résultat, facteur	12 mois	Analystes SOC
Navigation web	Catégorie d'URL, horodatage, volume	6 mois	Analystes SOC
Postes de travail (EDR)	Processus, fichiers, connexions réseau	12 mois	Analystes SOC
Administration à privilèges	Session complète enregistrée	24 mois	RSSI et audit
Applications sensibles	Consultation, export, modification	24 mois	Propriétaire et SOC
Messagerie (métadonnées)	Expéditeur, destinataire, objet, horodatage	12 mois	Analystes SOC

Point d'attention. *Tout collaborateur peut exercer ses droits d'accès et de rectification sur les données le concernant auprès du délégué à la protection des données, dont les coordonnées figurent sur l'intranet.*

11. Signalement, qualification et traitement des incidents de sécurité

La rapidité de la détection et de la réaction détermine l'ampleur de l'impact : chaque minute compte.

Constitue un incident de sécurité tout événement portant atteinte ou susceptible de porter atteinte à la disponibilité, à l'intégrité ou à la confidentialité des informations ou des systèmes. Relèvent notamment de cette définition la compromission avérée ou suspectée d'un compte, l'infection d'un poste par un code malveillant, la perte ou le vol d'un équipement contenant des données professionnelles, l'envoi de données à un mauvais destinataire, la découverte d'une vulnérabilité non corrigée sur un système exposé, et la constatation d'un accès non autorisé à un local technique. Le doute doit toujours conduire au signalement : la qualification relève du centre opérationnel de sécurité et non de l'utilisateur.

Le signalement s'effectue par l'un des trois canaux disponibles en permanence : le bouton dédié dans la messagerie pour les messages suspects, l'adresse électronique de sécurité pour les signalements documentés, et le numéro d'astreinte pour toute situation urgente ou en cas d'indisponibilité des systèmes. Le signalement doit être immédiat et ne doit jamais être différé au motif de rassembler davantage d'éléments. En cas de suspicion de compromission d'un poste, l'utilisateur doit le déconnecter du réseau, filaire et sans fil, sans l'éteindre, afin de préserver les éléments volatils nécessaires à l'investigation.

Le traitement suit un processus en cinq phases : qualification et évaluation de la gravité, confinement pour limiter la propagation, éradication de la cause racine, rétablissement du service dans des conditions de sécurité vérifiées, puis retour d'expérience formalisé. Lorsque l'incident constitue une violation de données à caractère personnel, la notification à l'autorité de contrôle doit intervenir dans un délai de soixante-douze heures à compter de la prise de connaissance, et l'information des personnes concernées est requise lorsque le risque pour leurs droits et libertés est élevé. Le retour d'expérience est conduit sans recherche de responsabilité individuelle, dans une logique d'amélioration des dispositifs.

Réflexes immédiats en cas de suspicion de compromission

- Déconnecter le poste du réseau sans l'éteindre ni le redémarrer.
- Ne pas tenter de supprimer soi-même des fichiers ni de désinstaller un programme suspect.
- Signaler immédiatement par téléphone à l'astreinte sécurité.
- Noter l'heure précise et la description factuelle des événements observés.
- Ne pas utiliser un autre poste avec les mêmes identifiants avant validation du SOC.
- Conserver le message ou la capture d'écran sans les transférer à des tiers.

Échelle de gravité et délais de réaction

Niveau	Définition	Exemple	Délai de prise en charge	Escalade
G1 — Critique	Impact majeur, activité arrêtée	Rançongiciel actif, fuite massive	15 minutes, 24/7	COMEX et cellule de crise
G2 — Élevée	Impact significatif, périmètre limité	Compte à privilèges compromis	1 heure, 24/7	RSSI et DSI

Niveau	Définition	Exemple	Délai de prise en charge	Escalade
G3 — Modérée	Impact limité, contournement possible	Poste infecté isolé	4 heures ouvrées	Responsable sécurité opérationnelle
G4 — Faible	Sans impact immédiat	Tentative d'hameçonnage bloquée	1 jour ouvré	Traitement SOC courant

Point d'attention. Éteindre un poste compromis détruit la mémoire vive, qui contient souvent les clés de chiffrement et les traces du processus malveillant. Déconnecter, oui ; éteindre, non.

12. Conformité, sensibilisation, contrôle et évolution de la charte

La sécurité se maintient par un cycle continu de mesure, de formation et d'adaptation du référentiel.

Le dispositif de sécurité s'inscrit dans un cadre réglementaire dense. Le règlement général sur la protection des données impose la mise en œuvre de mesures techniques et organisationnelles appropriées, la tenue d'un registre des traitements et la notification des violations. La directive NIS 2, transposée en droit national, étend les obligations de gestion des risques et de déclaration d'incidents à un périmètre élargi d'entités, dont l'organisation relève au titre de son secteur d'activité. S'y ajoutent les exigences contractuelles de certains clients, notamment la conformité au référentiel ISO/IEC 27001 dont la certification a été obtenue en 2023 et renouvelée en 2026.

Le programme de sensibilisation combine plusieurs modalités complémentaires. Un module de formation en ligne obligatoire d'une durée de quarante-cinq minutes doit être suivi annuellement par l'ensemble des collaborateurs, avec un quiz de validation exigeant un score minimal de 80 %. Des campagnes de simulation d'hameçonnage sont conduites trimestriellement, suivies d'un module court et bienveillant pour les personnes ayant cliqué. Des sessions présentiels spécifiques sont organisées pour les populations exposées : direction générale, finance, ressources humaines, assistants de direction et développeurs. Un bulletin mensuel diffuse les menaces d'actualité et les retours d'expérience anonymisés.

Le contrôle du respect de la charte s'exerce par des audits périodiques, des revues d'habilitations, des tests d'intrusion annuels conduits par un prestataire externe qualifié, et des exercices de crise simulant un incident majeur. Les constats alimentent un plan d'amélioration continue suivi en comité de sécurité trimestriel. La charte elle-même est révisée au minimum tous les deux ans et à chaque évolution significative du contexte technique ou réglementaire. Toute nouvelle version fait l'objet d'une information des instances représentatives du personnel et d'une communication à l'ensemble des utilisateurs, dont l'acceptation est recueillie lors de la première connexion suivant la publication.

Indicateurs de pilotage du dispositif de sécurité

Indicateur	Cible	Réalisé 2025	Tendance
Taux de couverture MFA	100 %	99,4 %	Stable
Taux de complétion de la formation annuelle	> 95 %	91,2 %	En hausse
Taux de clic aux simulations d'hameçonnage	< 8 %	8,2 %	En baisse
Taux de signalement des simulations	> 50 %	51,3 %	En hausse
Postes conformes au socle de durcissement	> 98 %	96,7 %	En hausse
Vulnérabilités critiques hors délai	0	3	En baisse
Délai médian de détection d'un incident	< 4 heures	6 h 20	En baisse

Indicateur	Cible	Réalisé 2025	Tendance
Comptes inactifs de plus de 90 jours	0	17	Stable

Point d'attention. La signature de la charte n'est pas une formalité administrative : elle rend ses dispositions opposables et engage individuellement chaque utilisateur dans le dispositif collectif de protection.